

Individuell inlämningsuppgift

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

MITRE ATT&CK ger ett gemensamt sätt att förstå hur angripare agerar – deras metoder, beteenden och mål. Det används både före och efter en attack. Red team kan testa tekniker, och blue team kan sedan se vilka larm som gick igång – och vad som missades. Efter en incident hjälper ramverket till att gå igenom vad som hände steg för steg, så man ser var försvaret brast och vad som behöver fixas. Det skapar också ett gemensamt språk mellan team och ledning. Istället för att alla använder olika ord för samma sak blir det tydligare vad som behöver prioriteras – oavsett om det handlar om åtgärder, budget eller personal.

Uppgift 2

MITRE ATT&CK är inte en checklista utan ett analytiskt verktyg för att beskriva och förstå angripare och deras attackkedjor. Det fokuserar på beteenden, mål och metoder på en generell nivå.

En angreppsinstruktion är något annat: den innehåller konkreta kommandon, verktyg och exakta steg för att ta sig in i ett system. Det innebär att samma teknik eller taktik kan genomföras på flera olika sätt. Till exempel kan en angripare skicka ett mejl med en skadlig länk eller en skadlig fil. Båda hamnar under samma kategori i ATT&CK, men utförs olika: den ena leder till en falsk inloggningssida, den andra kör skadlig kod. Hade det varit en angreppsinstruktion hade den beskrivit exakt vad filen innehåller, vad den ska göra och vilka steg som krävs för att lyckas med attacken.

Uppgift 3

Credential access: Angriparen vill få tag på tex inloggningsuppgifter som kan ge åtkomst.

Initial access: Angriparen försöker hitta första vägen in i ett system.

Persistence: Angriparen vill försöka hålla sig kvar länge i systemet.

Lateral movement: Angriparen vill försöka ta sig vidare inom systemet till andra delar.

Collection: Angriparen samlar information som är intressant för måltavlan.

Uppgift 4

Red team frågar sig: "Kan vi göra detta?" De använder ATT&CK för att dokumentera vilka taktiker och tekniker de har testat. Blue team tänker: "Hur kan vi upptäcka och stoppa detta?" För dem blir ramverket ett sätt att beskriva vilka beteenden som går att se i loggarna och hur försvaret kan stärkas. Ledningen frågar: "Hur viktigt är detta?" De får en överblick över vilka sårbarheter som finns och kan använda det för att prioritera tid, budget och personal. ATT&CK fungerar som ett gemensamt språk som minskar missförstånd. Red team testar tekniker, blue team ser vad som larmade eller inte och ledningen kan sedan besluta om vilka åtgärder som ska prioriteras. Det ger också spårbarhet: man kan se vad som har testats, vad som fungerade och vad som behöver följas upp senare. På så sätt jobbar alla mot samma mål, även om varje grupp använder informationen på sitt sätt.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Tactic: vad är målet

Technique: vad är metoden

Procedure: hur genomfördes det

Exempelvis så vill en angripare komma åt en inloggning (tactic), angriparen använder sig av phishing (technique) så angriparen skickar ut mejl som ser ut att komma från en betrodd användare med skadlig länk (procedure).

Uppgift 6

Tactic: lateral movement, technique: taint shared content, procedure: angriparen lägger in ett skadligt dokument i det gemensamma lagringsutrymmet som ger angriparen möjlighet att sprida sig vidare i andra delar av organisationen hos användare som öppnar dokumentet.

Tactic: collection, technique: browsersession hijacking, procedure: angripare hijackar en aktiv webbsession och får tillgång till den aktiva sessionen och samlar relevant data.

Tactic: impact, technique: network denial of service, procedure: angripare skickar massor av förfrågningar samtidigt så ingen vanlig användare kan komma åt tjänsten.

Uppgift 7

Tactic: impact

Technique: network denial of service, för att det gör tjänsten otillgänglig genom att överbelasta den.

Technique: data destruction, för att angriparen förstör data i syfte att påverka verksamheten negativt.

Technique: data encrypted for impact, för att det gör att data blir oåtkomlig för verksamheten.

Uppgift 8

En enskild observation räcker ofta inte för att dra säkra slutsatser. Man behöver se vad som hände före och efter, vilken användare det gällde och på vilket system det skedde – annars blir bedömningen osäker. För att få tillräcklig information måste man samla in mer data att jämföra med. Om loggar eller annan data håller låg kvalitet blir det svårt att göra en korrekt analys. Ett sätt att hantera det är att jämföra med andra rapporter och analyser. Det kan ge ledtrådar om vad mer som behöver undersökas och hjälpa till att göra en mer träffsäker bedömning.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

1. Initial access – skaffa första åtkomsten till systemet.
2. Persistence – se till att kunna hålla sig kvar.
3. Lateral movement – förflytta sig vidare i nätverket.
4. Collection – samla in relevant information.
5. Impact – orsaka påverkan på verksamheten.

Uppgift 10

1. Taktik: Få åtkomst till systemet

Teknik: Phishing

Procedur: Angriparen skickade ett mejl med en falsk inloggningssida.

2. Taktik: Hålla sig kvar i systemet

Teknik: Account manipulation: device registration

Procedur: Angriparen registrerade sin enhet på det kapade kontot för att kringgå eller uppfylla MFA-krav och behålla åtkomsten.

3. Taktik: Röra sig vidare i systemet

Teknik: Taint shared content

Procedur: En skadlig fil delades i den gemensamma lagringen. De användare som öppnade den gav angriparen åtkomst till sina konton.

4. Taktik: Samla relevant information

Teknik: Data from information repositories

Procedur: Angriparen hittade och fick tillgång till data som var värdefull för verksamheten.

5. Taktik: Göra data otillgänglig för ekonomisk vinning

Teknik: Data encrypted for impact

Procedur: Med informationen från steg 4 visste angriparen exakt vad som skulle krypteras. Nu begärs en summa pengar för att låsa upp filerna igen.

Uppgift 11

Det jag behöver veta är hur loggarna ser ut för att kunna verifiera vilka system och användare som påverkats. Jag vill också se om en ny enhet faktiskt registrerades på de kapade kontona. Jag behöver loggar och mer information om vad som hände före och efter varje observation. Vem öppnade det skadliga dokumentet?

Vilka filer, databaser eller annan information fick angriparen tillgång till? Utan rätt information går det inte att säkert säga hur angriparen höll sig kvar i systemet, om den lyckades röra sig lateralt, vart den tog sig, eller om den fick tillgång till mer än det som användes i slutmålet alltså impact-delen.

Uppgift 12

- 1.Rekognosering – Angriparen samlar information om målet, till exempel e-postadresser, använda tekniker och exponerade tjänster.
- 2.Initial åtkomst (Initial Access) – Första fotfästet skaffas, ofta via phishing, utnyttjande av en sårbarhet eller med stulna inloggningsuppgifter.
- 3.Exekvering (Execution) – Skadlig kod eller kommandon körs på det komprometterade systemet.
- 4.Beständighet (Persistence) – Angriparen säkrar fortsatt åtkomst, till exempel genom schemalagda uppgifter, registerändringar eller en bakdörr.
- 6.Behörighetsökning (Privilege Escalation) – Rättigheter höjs för att nå mer känsliga resurser.
- Förflyttning (Lateral Movement) – Angriparen sprider sig internt till fler system och konton för att komma närmare sitt mål.
- 7.Påverkan (Impact) – Slutmålet genomförs: kryptering (ransomware), dataförstöring, utpressning, serviceavbrott eller liknande.

Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

1. Utbilda personalen i phishing och försöka ha något typ av filter eller varning vid länkar.
2. Ha ett varningssystem för nya registrerade enheter och ett extra verifieringssteg vid registrering av ny enhet.
3. Att scanna filer och ha larm för ovanliga eller misstänkta filändringar.
4. Larm för ovanligt åtkomstmönster.
5. Ha backup så att det som blivit krypterat inte går förlorat.

Uppgift 14

1.Account manipulation: device registration

En möjlig detektionssignal är att en ny enhet registreras från en ovanlig plats, vid en konstig tidpunkt eller i samband med annan misstänkt aktivitet.

2.Taint shared content

Här kan en signal vara att en fil läggs till eller ändras på ett sätt som avviker från användarens normala beteende – till exempel vid ovanliga tider, i en mapp som normalt inte används, eller i ett okänt filformat. Det kan också vara att flera användare öppnar samma fil och sedan trigger liknande säkerhetslarm eller visar ovanlig aktivitet på sina konton eller system.

Uppgift 15

1.Account manipulation: device registration

För att minska risken kan man begränsa vilka som får lägga till nya enheter och ställa krav på vilka typer av enheter som får registreras. Samtidigt bör nya eller okända enheter trigga en varning så att de upptäcks snabbt.

2.Data encrypted for impact

För att minska konsekvenserna bör man regelbundet säkerhetskopiera och lagra kopiorna i en separat miljö, så att data går att återställa. Det är också bra att ha en färdig plan för hur incidenten hanteras – till exempel hur man isolerar drabbade system och stoppar spridning. För att minska risken bör åtkomst begränsas enligt principen least privilege – alltså att användare bara får de rättigheter de faktiskt behöver.

Uppgift 16

Först och främst får teamet en tydlig överblick över hur attacken gick till från start till mål. Det gör det lättare att förstå exakt vad som hände.

Eftersom attackkedjan är uppdelad i faser blir det enklare att se var de svaga länkarna finns men också var systemet är starkt och vad fungerar bra.

Det ger teamet möjlighet att gå igenom allt steg för steg och identifiera vad som behöver förbättras. Om angriparen kom in via phishing kan man undersöka vad som brast: behövde personalen bättre utbildning, saknades varningar för misstänkta mejl, eller finns det inte ens ett varningssystem?

Med informationen från attackkedjan kan man också jämföra varje fas med loggar och larm. Då syns det om något borde ha larmat men inte gjorde det, eller om det fanns tecken i loggarna som borde ha flaggats. Ibland kan man också se samband mellan händelser som kunde ha lett till tidigare upptäckt.

Attackkedjan hjälper också till att prioritera – allt kan inte fixas på en gång, så den visar vad som behöver åtgärdas först.

Vid uppföljning kan man använda samma kedja för att kontrollera om vidtagna åtgärder faktiskt har förbättrat förmågan att upptäcka, förebygga eller begränsa liknande attacker i framtiden.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

<https://attack.mitre.org/matrices/enterprise/> : mitre att&ck ger en överblick över beteende mönster och tillvägagångssätt avangripare.

<https://www.cisecurity.org/controls> : CIS controls är samlat best practice guidelines för att skydda sig mot vanliga cyberhot.

<https://www.nis-2-directive.com/> : NIS2 är grundkrav på säkerhet och incidenthantering på EU nivå.

Uppgift 18

Jämför observationen och omständigheterna med till exempel MITRE ATT&CK och andra rapporter eller analyser. Det hjälper till att bedöma sannolikheten och reda ut osäkerheter. Kolla också om det är rimligt att tekniken eller taktiken går att genomföra i det aktuella systemet. Låt gärna flera i teamet bidra med olika synvinklar och tankar, det ger en bredare bild och minskar risken för att något missas.

Uppgift 19

1. Hoten är tydligt beskrivna.
2. Relevant TTP är gjort kopplad till mitre att&ack.
3. Observationer och antaganden är tydligt separerad från fakta.
4. Potentiella risker och konsekvenser är listade.
5. Källor som använts i analysen är listade.
6. Rekommenderade försvarsåtgärder finns beskrivet.
7. Analysen har granskats av åtminstone en annan team medlem.

Uppgift 20

En hotanalys blir användbar när den är skriven så att mottagaren förstår och kan använda informationen.

Säkerhetsteamet vill ofta ha mer detaljer om taktiker, tekniker och loggar. Ledningen behöver istället veta vilka risker och hot som finns, hur allvarliga de är, och vad som bör prioriteras när det gäller resurser och budget.

Analysen blir också mer användbar om den är tydlig, har ett enkelt språk och en bra struktur som gör det lätt att följa hur hot, risker och observationer har analyserats.

Det är viktigt att det framgår vilka observationer, loggar, rapporter och källor analysen bygger på så att det är klart att informationen stödjer bedömningen. Det bör också vara tydligt vad som är fakta och vad som är osäker information eller spekulation. Det minskar missförstånd och gör det lättare för mottagaren att tryggt avgöra nästa steg.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

1. Dela backlog om inventering i två: lista organisationens tillgångar och sammanställ en lista på godkända mjukvaror har olika prioritering och bör därför vara separata.
2. Utöka vår definition of done: fler punkter ger mer tydlighet.
3. Skapad en checklista inför workshop 3: bra med struktur.
4. Lagt till att planera nästa steg: det är bra att kunna planera hur arbetet ska läggas upp.
5. Skapa en TTP tabell: förberedelse inför nästa projekt.

Uppgift 22

Vår sprint goal fokuserade framförallt på att bygga upp vårt team och skapa ett tydligt arbetssätt och struktur och kommer att behöva justeras med addering anpassat till nästa projekt.

Uppgift 23

Har vi nått vårt mål? Om inte, varför? Om ja, vad gick bra?

Har vårt arbetssätt funkat eller måste vi ändra något?

Uppgift 24

1. Vi uppdaterade vår backlog.
2. Vi hade gärna fått en demonstration på det agila arbetet så vi behöver ställa flerfrågor.
3. Vi har regelbundna möten som vi känner oss nöjda och som funkar bra.
4. Vi har skapat checklistor.
5. Vi planerar våra möten bra och skriver våra protokoll som vi ska.

Rekommenderade referenser

- MITRE ATT&CK:

<https://attack.mitre.org/>

- MITRE ATT&CK Enterprise Matrix:

<https://attack.mitre.org/matrices/enterprise/>

- CISA - Best Practices for MITRE ATT&CK Mapping:

<https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>

- MITRE ATT&CK Data & Tools:

<https://attack.mitre.org/resources/attack-data-and-tools/>

AI-användning: Jag använde Perplexity som jag promptade till anpassad studiehjälp för mina behov för att få hjälp att förstå vissa delar, korta ner vissa texter till sammanfattning och resonera om jag förstått rätt och hjälpa mig att formulera mina tankar. All text är dock skriven av mig.